

Linux Hardening Project — Audit e remediation su Kali Linux

Ambiente: Kali Linux (VM UTM, Apple Silicon)

Tipo di lab: Blue team / system hardening

Obiettivo:

Eeguire un audit di sicurezza di base sulla propria installazione Kali Linux, identificare configurazioni non ottimali ereditate dai default di sistema, e correggerle una a una, documentando ogni intervento in formato before/after con comando e relativo output.

Metodologia:

Audit strutturato per aree successive: utenti e permessi di accesso, servizi di rete esposti, stato degli aggiornamenti di sistema.

1. Audit utenti — chi può accedere al sistema

Comando:

```
cat /etc/passwd
```

Output (estratto rilevante):

```
root:x:0:0:root:/root:/usr/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin ...
postgres:x:117:120:PostgreSQL
administrator:/var/lib/postgresql:/bin/bash ...
kali:x:1000:1000:kali,,,:/home/kali:/usr/bin/zsh
```

Interpretazione: la maggior parte degli account (daemon, bin, sys, games, mail, ecc.) ha correttamente `/usr/sbin/nologin` o `/bin/false` come shell — sono account di servizio, nessun problema. Da qui parte il passo successivo, filtrare solo chi ha una shell realmente utilizzabile.

Comando (filtro mirato):

```
grep -E "/bin/bash|/bin/sh|/usr/bin/zsh" /etc/passwd
```

Output:

```
postgres:x:117:120:PostgreSQL  
administrator:/var/lib/postgresql:/bin/bash  
kali:x:1000:1000:kali,,,:/home/kali:/usr/bin/zsh
```

(oltre a root, già visibile nel comando precedente)

Interpretazione: tre account con shell attiva — root e kali attesi, postgres no. Un account di servizio database con shell di login è una configurazione più permissiva del necessario.

Comando (conferma):

```
grep postgres /etc/passwd
```

Output:

```
postgres:x:117:120:PostgreSQL  
administrator:/var/lib/postgresql:/bin/bash
```

Remediation — verificato che l'account postgres non viene mai usato per login manuale diretto nel workflow abituale della macchina:

Comando:

```
sudo usermod -s /usr/sbin/nologin postgres
```

Output: (nessuno — comportamento standard, usermod non stampa conferma se l'operazione riesce)

Verifica post-fix:

```
grep postgres /etc/passwd
```

Output:

```
postgres:x:117:120:PostgreSQL  
administrator:/var/lib/postgresql:/usr/sbin/nologin
```

2. Audit servizi di rete in ascolto

Comando:

```
sudo ss -tulpn
```

Output:

```
Netid State Recv-Q Send-Q Local Address:Port Peer Address:Port
Process udp UNCONN 0 0 [fe80::7438:f2ff:fe3a:1dc]@eth0:546 [:::]*
users:(("NetworkManager",pid=587,fd=24)) tcp LISTEN 0 128 0.0.0.0:22
0.0.0.0:* users:(("sshd",pid=700,fd=6)) tcp LISTEN 0 128 [:::]22
[:::]* users:(("sshd",pid=700,fd=7))
```

Interpretazione: solo due servizi realmente in ascolto – il client DHCPv6 di NetworkManager (normale, non è un servizio esposto ad attacco) e SSH (sshd), in ascolto sia su IPv4 (0.0.0.0:22) sia su IPv6 ([:::]22), quindi raggiungibile da qualsiasi indirizzo.

Valutazione: confermato che il workflow abituale della macchina non prevede accesso remoto via SSH. Servizio esposto ma non utilizzato → superficie d'attacco non necessaria da rimuovere.

Remediation:

```
sudo systemctl stop ssh
sudo systemctl disable ssh
```

Output: (nessuno stampato – comportamento standard di systemctl quando l'operazione riesce)

Verifica post-fix:

```
sudo ss -tulpn
```

Output: Le due righe relative a sshd non compaiono più – porta 22 non più esposta.

3. Audit aggiornamenti di sistema

Comando:

```
sudo apt update
```

Output (riga finale):

2305 packages can be upgraded. Run 'apt list --upgradable' to see them.

Interpretazione: backlog molto significativo — segnale di sistema non aggiornato da tempo, potenziale esposizione a vulnerabilità già corrette upstream ma non ancora applicate localmente.

Remediation avviata:

```
sudo apt upgrade -y
```

Output (estratto, interrotto manualmente):

```
Get:886 http://kali.mirror.garr.it/kali kali-rolling/main arm64  
liblsan0 arm64 16 30% [886 liblsan0 9,869 B/1,213 kB 1%] [Waiting for  
headers] ... Get:891 http://kali.download/kali kali-rolling/main  
arm64 libhwasan0 arm64 16.2.0 30% [891 libhwasan0 9,632 B/1,505 kB  
1%] [Waiting for headers] ^C
```

Messa in sicurezza post-interruzione:

```
sudo dpkg --configure -a
```

Output: (nessun pacchetto risultava a metà configurazione al momento dell'interruzione — comando eseguito comunque come rete di sicurezza standard)

Riepilogo before/after:

Area: Shell utente postgres

- Prima: `/bin/bash` (login possibile)
- Dopo: `/usr/sbin/nologin`

Area: Servizio SSH

- Prima: Attivo su 0.0.0.0:22 e [::]:22
- Dopo: Fermato e disabilitato

Area: Aggiornamenti di sistema

- Prima: 2305 pacchetti in sospeso
- Dopo: Upgrade avviato, interrotto al 30% – da completare in una prossima sessione (`sudo apt upgrade -y`, riprenderà da dove si era fermato)

Cosa ho imparato:

- Come distinguere, tra decine di account di sistema, quelli con reale potenziale di accesso interattivo (`grep -E` su pattern di shell)
- L'importanza di verificare l'uso reale di un servizio prima di disattivarlo, non disattivare "a caso"
- Uso di `ss -tulpn` per un audit di rete lato server/host (complementare a Nmap, che guarda la stessa cosa dall'esterno)
- Gestione sicura dell'interruzione di un'operazione di sistema lunga (`Ctrl+C + dpkg --configure -a` come rete di sicurezza)

Nota operativa:

dato il volume di pacchetti (2305) e i tempi stimati da apt stesso (fino a diverse ore), l'operazione è stata interrotta manualmente al 30% di completamento (Ctrl+C , visibile come ^C a fine output) per vincoli di tempo della sessione.